

Confidentiality- concept used to protect secrecy; **countermeasures** against attacks include encryption, network traffic padding, strict access controls, rigorous authentication procedures, data classification, extensive personnel training

Integrity- concept of protecting correctness & reliability of data prevents unauthorized alteration of data; **countermeasures** against attack strict access controls, rigorous authentication procedures, IDS, object/data encryption, hash verification, interface restrictions, input/function checks

Availability- authorized subjects granted timely and timely and uninterrupted access to objects **countermeasures** against attack designing intermediary delivery systems properly, using access controls effectively, monitoring performance & network traffic, using firewalls and routers to prevent DoS attacks, implement redundancy for critical systems, maintain & testing backup systems

Over protecting **confidentiality** can result in restriction of **availability**; Over protecting **integrity** can restriction against **availability**; Over providing **availability** can result in loss of **confidentiality & integrity**.

AAA services core mechanism of all security environments

Authentication: proving you are a claimed identity

Authorization: defining the permission of resource/object access for identity or subject

Accounting: reviewing of log files to check for compliance violations in order to hold subjects accountable for their actions

5 Elements of AA Services: Identification, Authentication, Authorization, Auditing, Accounting

Threat Modeling: is a security process where potential threats are identified, categorized & analyzed; ultimate goal of threat modeling is to prioritize the potential threat against an organization's assets; it can be performed **proactive** measure during design & development or as **reactive** measure once a product is deployed; Example Models below:

STRIDE: developed by Microsoft threat model Spoofing, Tampering, Repudiation, Information disclosure, DoS, Elevation of Privileges

PASTA: Process for Attack Simulation & Threat Analysis; aims at selecting countermeasures in relation to the value of the assets to be protected ; 7 PASTA steps:

Step 1: DO Definition of Objectives

Step 2: DTS Definition of Technical Scope

Step 3: ADA Application Decomposition Analysis

Step 4: TA Threat Analysis

Step 5: WVA Weakness /Vulnerability Analysis

Step 6: AMS Attack Modeling & Simulation

Step 7: RAM Risk Analysis & Management

VAST- Visual, Agile & Simple Threat concept that integrates threat & risk management into an Agile programming environment on a scalable basis

DREAD: Disaster, Reproducibility, Exploitability, Affected Users & Discoverability rating system design to provide flexible rating solution; DREAD questions:

Damage Potential How severe is the damage likely to be if the threat is realized?

Reproducibility How complicated is it for the attacker to reproduce exploit

Exploitability How hard is it to perform the attack

Affected Users How many users are likely to be affected (%)

Discoverability How hard is it for attacker to discover weakness

NEXT STEPS AFTER THREAT MODELING

Potential attack concepts can be determined using **diagramming**.

NEXT STEP AFTER DIAGRAMMING

Reduction Analysis/ Decomposition: gain greater understanding of the logic of the product,, its internal components as well as interaction w/ external elements; **5 Step Process**:

Trust Boundaries any location where the level of trust or security changes

Dataflow Paths movement of data between locations

Input Points locations where external input is received

Privileged Operations any activity that requires greater privilege than of a standard user account or process, typically required to make system change or alter security

Details about Security Stance & Approach declaration of security policy, security foundations & security assumptions

Identity & Access Management (IAM) system of a organization that provision the account & assign necessary privileges & access

RISK = THREAT * VULNERABILITY

Qualitative Risk Analysis- is more scenario based; uses high damage -low damage, highly likely- unlikely to occur

Delphi Technique is anonymous feedback & response process used to enable a group to reach an anonymous consensus

Quantitative Analysis concrete probability indicators or a numeric indication of relative risk potential; end report is in \$

(AV)Asset Value \$

(EF) Exposure Factor %

(SLE) Single Loss Expectancy = ASSET VALUE * EXPOSURE FACTOR

(ARO) Annualized Rate of Occurrence #/ Years

(ALE) Annualized Loss Expectancy most commonly needed in determining criticality prioritization; largest ALE is the biggest problem org is facing should be addressed first in risk response $ALE = SLE * ARO$

Risk Response: Mitigation or Reduction, Assignment or Transfer, Deterrence, Avoidance, Acceptance, Reject or Ignore

TOTAL RISK – CONTROL GAPS = Residual Risk

ALE (Pre Safeguard) – ALE (Post Safeguard) = value of safeguard; if result is negative the safeguard is not a good choice; annual cost of safeguard should not exceed asset value loss

EXAMPLE: AV = 200,000 EF= 45%
 SLE = 200,000 *45%= 90,000
 ARO = .5
 ALE = 90,000 * .5 = 45,000

Security Control Assessment (SCA)- is a formal evaluation of a security infrastructure individuals mechanisms against a baseline or reliability expectation Enterprise Risk Management (ERM)- can be evaluated using (RMM) Risk Maturity Model Levels: Ad hoc- Chaotic Preliminary- loose attempts made to follow risk management processes Defined common or standardized risk framework adopted organization wide Integrated- Risk management operations are integrated into business processes; risk considered an element in business strategy decisions Optimized- Risk Management focuses on achieving objectives rather than just reacting to external threats	Risk Framework is a guideline or recipe for how risk is to be assessed, resolved, & monitored; NIST SP 800-37 established RMF Risk Management Framework 6 Phases: Prepare establish context priorities for managing security & privacy risk Categorize system & info processed, stores & transmitted by the system analysis of impact of loss Select initial set of controls for system tailor the control as needed to reduce risk to acceptable level Implement controls & describe how the controls are employed w/ system & environment of operations Assess controls to determine that risk to organization are acceptable Monitor system & associated controls on an ongoing basis to include assessing control effectiveness ISO/ IEC31000 Risk Management Guidelines Guidance for Implementation ISO/IEC27005 Information Technology Security techniques- Information Security Risk Management FAIR Factor Analysis of Information Risk
--	--

(BCP) Business Continuity Planning provide a quick calm& effective response in the event of an emergency & to enhance a company’s ability to recover from a disruptive event promptly; 4 Steps of BCP process:

Project Scope & Planning create BCP team, assess resources

Business Impact Anaylsis qualitative analysis, quantitative analysis; 5 stages of BIA: Identificationof Priorites, Risk Identification, likelyhood assessment, impact analysis & resource prioritization

Continuity Planning focus on how an organization will carryout critical business fucntionsbegining shortly after disruption & extending for up to one month os start of operations

Approval & Implementation endorsed by senior executive, plan imlementation, training/edication, statement of priorities/importance

Laws, Regulations & Compliance : **Criminal Law** protects society against acts that violate the basic principles we believe in prosecuted by federal & state gov;

Civil Law provide the framework for transaction of business between people & organizations violations are brought to court and argued by 2 parties;

Administrative Law is used by government agencies effectively carryout day to day business

Computer Fraud &Abuse Act (CFAA) protects computers used by government agencies or in interstate commerce from a variety of abuses

Federal Sentencing Guidelines prudent man rule; requires senior executives to take responsibility for ensuring due care

Electronic Communication Privacy Act (ECPA) makes it a crime to invade the electronic privacy of an individual

Federal Information Security Management Act (FISMA) requires federal agencies to implement a formal information security program that covers the agencies operations to include contractors insecurity management program NIST developed FISMA implementation guidelines

COMMON NIST STANDARDS: **NIST SP 800-53-** Security & Privacy Controls for Federal Information Systems& organizations standard requires for federal systems; **NIST SP 800-17-** Protecting Controlled Unclassified Information in non federal info systems& organizations federal contractors must comply

NIST Cyber Security Framework (CSF) set of standards designed as voluntary risk-based framework for securing info systems

Digital Millennium Copyright Act prohibits circumvention of copy protection mechanisms placed in a digital media & limits the liability of internet service providers for the activities of their users

Economic Espionage Act of 1996 provides penalties for individuals found guilty of theft of trade secrets; harsher penalty if info benefits a foreign government

ITAR International Traffic in Arms Regulations controls the export of items that are specifically designated as military & defense items including technical info related to that item

EAR Export Administration Regulations designed for commercial use but may have military application

Communication Assistance for Law Enforcement Act (CALEA) requires all communication carriers to make wiretaps possible for law enforcement w/ appropriate order

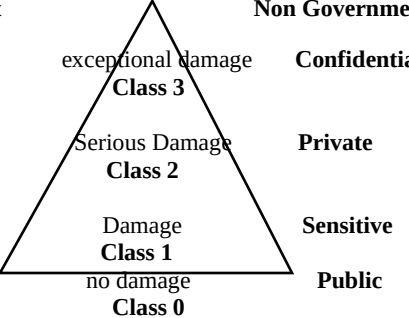
Childrens online Privacy Protection Act (COPPA) makes a series of demands on websites that cater to children or knowingly direct info about children

Family Educational Rights Privacy Act (FERPA) grants privacy for students over 18 & the parents of minor students

General Data Protection Regulations (GDPR) that governs the use & exchange of personal info in the EU

Personal Info Protection & Electronic Document Act (PIPEDA) Canada governs use of personal info

Digital Rights Management (DRM) methods attempt to provide copyright protection for copyrighted works

Government Top Secret Secret Confidential Unclassified		Data Roles Data Owner person responsible for classifying, labeling & processing data System Owner responsible for systems that processes data Data controllers decide how data is processed & what data is processed Data Processors often third party that process data for company by direction of data controller Administrators grants access to data User access data while performing work tasks Custodian day to day duty protecting & storing data
		Data Loss Prevention (DLP) systems attempts to detect & block data exfiltration attempts: Network based DLP scans all outgoing data looking for specific data; places on edge of network Endpoint based DLP scans files stored on a system as well as files sent to external devices printers

Logical Operations :

^ - **and** checks whether two values are both true

v – **or** checks whether at least 1 input is true

~ - not reverse the value or input

⊕- **xor** returns true when only 1 input value is true

MOD modulo function returns remainder value after /

Cloud Access Security Broker (CASB) software between users & cloud based resources; monitors all activity enforce admin policy can detect shadowIT

Key Terminology

Control Objectives for Information & Related Technologies (COBIT) is a security concept infrastructure used to organize the complex security solutions of companies crafted by **ISACA** Info Systems Audit & Control Association

User Behavior Analytics (UBA) User Entity Behavior Analytics (UEBA) concepts of analyzing the behavior of users, subjects, visitors, customers for specific goal or purpose; info gathered from UEBA can be used to improve personnel security policies, procedures, training & related security programs

ATO- Authorization to Operate

EOL- End of Life point at which manufacturer no longer produces a product

EOSL- End of service systems that are no longer receiving updates & support from the vendor

Cryptology effects confidentiality : **Symmetric Cryptosystem** use shared secret key number of keys used in algorithm $n(n-1)/2$; **Asymmetric Cryptosystem** individual combinations of public & private key includes non repudiation

Transposition Cipher rearrange the letters of a plaintext message forming cipher text
Substitution Cipher use encryption algorithm to replace each character or bit of plaintext message
Onetime Pads aka vernom cipher can only be used once; key length is as long as message can be used short messages ; most secure if used properly

Cryptology Modes of Operations
Electronic Code Book (ECB) mode simplest & least secure each time algorithm processes a 64 bit block encrypts the block using chosen secret key meaning if the algorithm encounters the same encrypted block multiple times it will produce same encrypted block
Cipher Block Chaining (CBC) mode each block of unencrypted text is xored w/ block of ciphertext immediately preceding it before it is encrypted; decryption process decrypt process reversing xor process; implements the IV initial vector & xor with first block of message producing unique output
Cipher Feedback (CFB) mode is a stream cipher uses memory buffers of the same size block as the buffer becomes full it is encrypted then sent to recipients
Output Feedback (OFB) mode xor’s plaintext w/ seed value there is no chaining function & transmission errors do not propagate or affect decrypt of future blocks
Counter Mode(CTR) uses a stream cipher that increments for each operation, errors do not propagate; allows you to break a encryption or decryption operation into multiple independent steps well suited for parallel computing
Galois Counter mode (GCM) take CTR mode & adds data authenticity controls, providing recipients assurance of integrity of data received; add authentication tags to encryption process
Counter w/ Cipher Block Chaining Message Authentication Code (CBC-MAC) combines confidentiality mode w/ data authenticity process
Symmetric Crypto Systems
Data Encryption Standard (DES) 64 bit block cipher block has 5 modes: ECB, CBC, CFB,OFB & CTR generates 64 bit block of ciphertext use 56 bit key length
3DES stronger than DES should be avoided due to insufficient key length
International Data Encryption Algorithm (IDEA) block cipher operates on 64 bit blocks of plaintext; uses 128 bit key length operates in 5 modes: ECB, CBC, CFB, OFB & CTR implementation found in PGP Pretty good Privacy secure email packages
Blowfish operates on 64 bit block of text uses variable key length 32-448 bits faster than IDEA & DES released for public commercial use w/ n license
Skipjack operates on 64 bit block of text uses 80 bit key support: CBC, ECB, CFB, CTR; supports escrow of encryption keys ;NIST & Dept of Treasury hold keys approved use by US gov in FIPS
Advanced Encryption Standard (AES) uses 128 bit (10 rounds of encryption), 192 bits(12 rounds), 256 bits (14 rounds) key length strengths
Twofish based on blowfish block cipher operates on 128 bit block capable using keys up to 256 bit lengths uses **prewhitening**: xor plaintext w/ separate subkey before round of encryption & **postwhitening** uses similar operation after 16th round of encryption

Standard for encrypting a message S/MIME
Standard for secure web traffic is http over TLS
IPSec protocol provides a common framework for encrypting network traffic as in built into common operating systems; IPSec **transport mode** contents (payload) are encrypted for peer-to-peer communication; **tunnel mode** entire packet including header is encrypted gateway-to-gateway communications

Process States: Ready is ready to resume or begin a process; **Running** process executing on CPU continuing until finish; **Waiting** process is waiting for continued execution but is waiting for I/O to continue; **Supervisory** used when a process must perform an action that requires more privilege; **Stopped** when a process finishes or must be terminated;
Operation Modes: User Mode basic mode used by CPU when executing user apps; **Privileged Mode** designed to give os access to the full range of instruction supported by CPU aka supervisory or kernel mode; All user applications including those systems running in administrators run in user mode; Privilege mode is used by request without the user controls system accepts or rejects request

Memory storage bank for information 2nd major hardware component
(ROM) Read only Memory can read but not change; often contain bootstrap info for startup POST
(PROM) Programmable ROM end users can burn into chips content; once altered no further changes can be possible
(EPROM) Erasable Programmable ROM can be erased using light; **UVEPROM** ultraviolet erasable;
EEPROM Electronically Erasable ROM electronically erases using voltages delivered to the pins of the chip to force erasure
Flash Memory derivative of EEPROM; nonvolatile form of storage media that can be electronically erased & written in blocks or pages
(RAM) Random Access Memory readable & writable memory that contains information a computer uses during processing; data loss when no power; **Dynamic RAM** uses capacitor to send electrical charge; needs to be refreshed cheaper; **Static RAM** use a flip flop doesn’t need refresh
TEMPEST protects electronics from electromagnetic pulse

Large Scale Parallel Data Systems designed to perform numerous calculations simultaneously include SMP,AMP & MPP; **Grid Computing** is a form of parallel distributed processing that loosely groups a significant number of processing nodes to work toward a specific processing goal; **Peer-to-Peer** technologies are networking & distributed app solutions that share tasks & workloads among peers
Industrial Control System (ICS) form of computer management device that controls industrial processes & machines (operation technology); ICS’s includes **Distributed Control Systems (DCs)** for small environments, **Programmable Logic Controllers (PLCs)**, **Supervisory Control & Data Acquisition (SCADA)** large environments
Service-Oriented Architecture (SOA) constructs new applications or functions out of existing but separate & distinct software services; **Microservices** derivative of SOA simple one element or one feature function of a web app can be used by different web ap

Software Defined Everything (SDx) replacing hardware & software w/virtualization
Software Defined Visibility (SDV) framework to automate the process of network monitoring & response make intelligence decision on responding to threats
Fog Computing used in IIOT relies on sensors, IOT devices, edge computing device to collect data & transfer back to central location centralizing intelligence & processing

Key Escrow & Recovery
Fair Cryptosystem secret keys used for communication are divided into two or more pieces, each given to independent third parties each piece being useless until reassembled
Escrow Encryption Standard provides government or authorized agent w/ technology means to decrypt ciphertext; proposed for clipper chip recover agent ability to recover encryption keys assigned for

Asymmetric Crypto System
(RSA) Rivest, Shamir & Adleman for commercial public use uses 3072 bit key length
El Gamal extension of Diffie Hellman doubles the size of any message that it encrypts is a disadvantage
(ECC) Elliptic Curve 256 bit key length used for mobile devices; equivalent to RSA 3072 bit key
Diffie Hellman algorithm is an approach to key exchange that allow two individuals to generate a shared secret key over unsecure communication channel
(ECDHE) Elliptic Curve Diffie Hellman key exchange is a variant
(SHA) Secure Hash Algorithm **SHA-3** make up government standard message digest function; **SHA-2** supports hash of variable lengths ranging up to 512 bits
MD5
RIPEDMD

Digital Signatures assures recipients that the message truly came from sender; assures recipients message are not altered while in transit; software vendors often use digital signature technology to authenticate code distributions that you download from internet i.e applet, software patch
Hashed Message Authentication Code (HMAC) implements a partial digital signature guarantees integrity of message during transmission doesn’t provide non repudiation
Digital Signature Standard (DSS) all federally approved digital signature algorithms use SHA3 hashing function; 3 approved standards: DSA, RSA, ECDSA

Transport layer security most well known example off hybrid cryptology

4 Layer Ring Protection (Ring 0-2 privilege mode)
Ring 0 o/s kernel/ memory (Resident component)
Ring 1 other o/s components **Ring 2 Drivers, Protocols; Ring 3 User Level Programs (user mode)**

Nonpersistent Systems or static systems is a computer system that doesn’t not support or retain change; between use & reboot operating env & installed software are exactly the same Containerization based on concepts of eliminating the duplication of OS elements in a virtual machine; Each app placed in a container that includes only resources needed to support enclosed app Arduino open source hardware & software organization that creates single-board 8-bit microcontrollers for building digital devices; Arduino has a limited RAM. Single USB port & I/O pins for controlling electronic doesn’t include OS or support networking; can execute C++ programs; stores code on flash chip not suited for mission critical operations Raspberry Pi single board computer includes custom OS more process power than Arduino not limited to C++; supports networking Real Time Operating System (RTOS) designed for mission critical operations where delay must be eliminated or minimal Field Programmable Gate Array (FPGA) flexible computing device intended to be programmed by end user or customer;disadvantage challenging to program	Secure Facility Plan Critical Path Analysis systematic effort to identify relationships between mission critical app, processes & operations & all the necessary supporting elements Crime Prevention Through Environmental Design (CPTED) addresses facility design w/ intention to create behavior effects 3 strategies: <i>natural access, natural surveillance, natural territorial reinforcement</i> Order of Controls for physical env: Deter, Deny, Detect, Delay, Decide Protected Cable Distribution (PDSs) (Protective Distribution Systems) means by which cables are protected against unauthorized access or harm Heartbeat Sensor mechanism where communication path is constantly or periodically checked w/ test signal Motion Detectos: Digital Motion Detector smart security camera monitor change in digital patt Passive Infrared (heat based) monitors significant changes in heat Wave Pattern transmits low ultrasonic or high microwave frequency for changes in pattern Capacitance senses changes in electrical or magnetic field surrounding monitored object Photoelectric senses change in visible light; used in rooms w/ no light Passive Audio listens for abnormal sounds Enhanced Video Surveillance (EVS) systems are capable of object detection Sensitive Compartmented Information Facility (SCIF) often used by gov or military provide a secure env for highly sensitive data storage & computati Perimeter Intrusion Detection & Assment Sys advanced fencing
Power Loss: Fault momentary loss of power, Blackout a complete loss of power, Sag momentary low voltage, Brown prolonged low voltage, Spike momentary high voltage, Inrush a initial surge of power usually associated w/ connecting to a power source Uninterruptible Power Supply (UPS) self charging battery can be used to supply consistent clean power to sensitive equipment ; Generator highest level of power protection	Security Controls Administrative physical security include physical construction, building design, site selection, personnel controls, training Technical physical security building access controls, IDS, alarms, cctv Physical fencing, lightning, locks, access control vestibules (mantrap) *Rooms containing computers should be kept at 59-89 degree F(15-32C) Humidity in room should be between 20 & 80%; Too much humidity can cause corrosion; Too less humidity can cause static electricity
Fire Prevention, Detection & Suppression Fire- chemical reaction caused by Heat, Oxygen, Fuel 4 stages of fire: Stage 1 Incipient Stage l only air no smoke; Stage 2 Smoke Stage visible from point of ignition; Stage 3 Flame Stage flame can be seen w/ naked eye; Stage 4 Heat Stage heat buildup everything burns Fixed Temperature Detection triggered once certain temperature is reached Rate of Rise triggered when speed of temperature reaches a certain level Flare Actuated trigger based infrared energy of flame Fire Extinguisher Classes Class A Commone Cumbustibles Suppress w/ water, soda acid, dry powder Class B Liquids Suppress w/ CO2, halon, soda acid, alternate gas Class C Electrical Suppress w/ CO2, halon, or alternate gas Class D Metal Suppress w/ Dry Powder Class K Cooking Suppress w/ Alkaline mistures *Water cant be used on B/K fires because it would vaporize causing the burning to spread in explosion Water Suppression Systems Wet Pipe System (closed head system) always full of water; water discharge immediately when suppression is triggered Dry Pipe System contains compressed inert gas; once suppression is triggered inert gas is released opening a water valve that causes pipes to fill w/ water then discharge Preaction System variation of dry pipe that uses a two storage detection & release mechanism most appropriate for env w/ humans & computers Deluge System uses larger pipes delivers a significant amount of water; not for electronic/ computers Gas Discharge System used compressed gas to extinguish fire; shouldn’t be used in env w/ people ; gas discharge removes oxygen from the air	OSI MODEL Open Systems Interconnection Model guiding principal in networking Protocol set of rules & restrictions that define how data is transmitted over a network Layer 7 Application Protocol Data Unit LDP(515), IMAP4(143) Layer 6 Presentation PDU Layer 5 Session PDU Layer 4 Transport TCP- Segment or UDP-Datagram Layer 3 Network Packet Layer 2 Data Link Frame Layer 1 Physical Bits Encapsulation addition of a header a possibly footer to data received by each layer from the layer above before its handed to layer below DeEncapsulation inverse action going up the OSI model TCP/IP Model aka DARPA or DoD model Application correspond OSI 5-7 Transport correspond OSI 4 Internet correspond OSI 3 Link corresnond OSI 1-2
Key Terminology Gait Analysis evaluates the way someone walks as a form of biometric authentication or identification; biological characteristic that can be used to differentiate between authorized individuals & unauthorized intruders Sanitation or zeroization process that can erase data by replacing w/ meaningless data such as zeros; process to remove all data remnants *Elasticity automates scalability	Protocol Analyzer tool used to examine the contents of network traffic can be hardware or software Socket combination of IP address & port number Well known ports (0 – 1023) service ports reserved for servers Registered Software ports (1024 – 49151) registered w/IANA Ephemeral/Random/Dynamic ports (49152 – 65535) IPV4 vs. IPV6 IPV4 uses 32 bit address; IPV6 uses 128 bit addressing Network Address Translation Protocol (NAT-PT) can be used to convert between IPV4 & IPV6 network segments similar to how NAT converts internal & external networks Communication Protocols Li-Fi Light Fidelity technology wireless comm uses light Satellite comm primarily based on transmitting radio waves between terrestrial locations& an orbiting artificial Zigbee IOT device comm concepts that based on bluetooth

Secure Communications Internet Protocol Security (IPSec) uses public key cryptography to provide encryption, access control, nonrepudiation & message authentication; all using IP-based protocols & primary uses is for VPNs virtual private network, operate in transport or tunnel mode Kerberos offers SSO solution for users & provides protection for logon credentials uses hybrid encryption Secure Shell (SSH) example of end-to-end encryption technique; used to encrypt plaintext utilities; functions as a transport mode VPN Signal Protocol provides end-to-end encryption for voice communication, videoconferencing & text message services Transport Layer Security (TLS) encryption protocol that operates at OSI layers 4 *LOKI using ICMP protocol is transformed into a tunnel protocol to support TCP communications	General Wireless Concepts Spread Spectrum communication occurs over multiple frequencies Frequency Hopping Spread Spectrum (FHSS) transmits data in series across a range of frequencies but only one frequency at a time is used Direct Sequence Spread Spectrum (DSSS) employs frequencies simultaneously in parallel, uses a chipping code to allow a receiver to reconstruct data if parts of the signal were distorted because of interference Orthogonal Frequency Division Multiplexer (OFDM) employs a digital multicarrier modulation scheme that allows for a more tightly compacted transmission Bluetooth 802.15 defined in IEEE uses 2.4 GHz frequency; <i>bluesmacking</i> is a DOS attack a Bluetooth device thru transmission of garbage traffic or signal jam
Wireless Networks 802.11 IEEE standard for wireless network communications Site Survey goal is to maximize performance in desired area Heatmap mapping of signal strength measured over a building blueprint RADUIS UDP (1812) encrypts password only Diameter based on RADUIS improves weakness not compatible with it TACACS+ TCP (49) encrypts the entire session WPA2 IEEE 802.11i defined Wi-Fi Protected Access 2 supports two authentication options: <i>Preshared Key (PSK) or Personal (PER)</i> & IEEE 802.1x or ENT enterprise uses AES-CCMP; vulnerable to KRACK & Dragon blood Attack WPA3 Wi-fi Protected access 3 uses 192 bit AES CCMP encryption, where as WPA3-PER is 128 bits AES CCMP ; WPA3-PER uses simultaneous Authentication of equals (SAE) Simultaneous Authentication of Equals (SAE) performs zero knowledge proof process known as Dragonfly Key exchange, which is a derivative of Diffie Hellman; process uses a preset password & MAC address of the client & AP to perform authentication & session key exchange Wi-Fi Protected Setup (WPS) security standard for wireless networking	Common Network Equipment System on a Chip (SOC) is an integrated circuit or chip that has all the elements of a computer integrated into a single chip; devices that use SOC include mini computer Raspberry PI, fitness trackers, smartwatch Firewalls Bastion Host is a system specifically designed to w/stand stacks such as <i>firewall appliance : can be a multifunction device (MFD), Unified Threat Management (UTM) or Next Generational Firewall (NGFW)</i> Static Packet Filtering firewall (Screening router) filters traffic by examining data from message header; stateless firewall each packet evaluated individually Stateless firewall analyzes packets on an individual basis against the filtering ACLs or rules Application Firewall filters traffic based on a single internet service, protocol or application; WAF Wen application firewall is example Circuit firewall (circuit proxies) used to establish communications sessions between trusted partners; stateless firewall TCP Wrappers is application that can serve as a basic firewall; form of port based access control Stateful Inspection firewall (Dynamic Packet Filtering) evaluates the state, session, or context of network traffic; stateful inspection firewalls operates at OSI layer 3 & up Deep Packet Inspection (DPI) payload inspection, or content filtering is the means to evaluate & filter the payload contents of a communication rather than only on header values Next Generation Firewall (NGFW) are multi function devices or UTM composed of several security features in addition to a firewall
Coaxial Cables Thinnet (10Base2) commonly used to connect systems to backbone trunks of thicknet cabling; can span distance of 185 meters & provide throughput up to 10Mbps Thicknett(10Base5) can span 500 meters & provide throughput up to 10Mbps Baseband cables can transmit only a single signal at a time Broadband Cables can transmit multiple signals simultaneously Shielded Twisted Pair metal foil wrapped around sheath Unshielded twisted Pair w/o foil 8 categories (CAT) Attenuation the degradation of a signal Fiber Optic Cables transmit pulses of light rather than electricity	Proxy variation of a application firewall or circuit level firewall; proxy server is used to mediate between clients & servers; proxies must often used in context of providing clients n a private network w/ internet access while protecting the identity of the client Forward Proxy acts as intermediary for queries of external resources Reverse Proxy handles requests from external systems to internal services
Network Topologies Ring Topology connects each systems as a point on a circle; uses a token Bus Topology connects each system to a trunk or backbone Star Topology employs a centralized device; Ethernet is a bus base topology Mesh Topology connects systems toother systems using numerous paths	Endpoint Security concepts of client/server model network is known as distributed system or distributed architecture
Local Area Network (LAN) Media Access Carrier Sense Multiple Access (CSMA) Carrier Sense Multiple Access w/ Collision Detection (CSMA/CD) Carrier Sense Multiple Access w/ Collision Avoidance (CSMA/CA) *802.11 wireless networking employs CSMA/CA; CSMA/CA attempts to avoid collisions by granting only a single permission to communicate at a given time	EAP Derivatives LEAP Lightweight Extensible Authentication Protocol Cisco proprietary alternative to TKIP for WPA; legacy and avoided PEAP Protected Extensible Authentication Protocol encapsulates EAP in TLS tunnel support mutual authentication EAP-SIM Subscriber Identity Module authenticates mobile devices over global systems for mobile communication (GSM) network each subscriber gets a sim for identification EAP-FAST Flexible Authentication via Secure Tunneling Cisco protocol to replace LEAP EAP-POTP Protected Onetime Password support use of One Time Password tokens in multifactor authentication EAP-TLS Transport Layer Security open standard that used in protecting authentication traffic ; most effective w/ digital certificate EAP-TTLS Tunneled Transport Layer Security creates a VPN-like tunnel between endpoints prior to authentication; nothing transmitted in cleartext *IEEE 802.1X defines use of encapsulated EAP to support a wide range of authentication options for LAN connections
Authentication Protocols Point to Point (PPP) encapsulation protocol designed to support transmission of IP traffic over dial-up or point to pint links; data link layer protocol Password Authentication Protocol (PAP) transmit username and password in plaintext Challenge Handshake Authentication Protocol (CHAP) use challenge response dialog can’t be replayed based on MD5 not used Extensible Authentication Protocol (EAP) framework for authentication not a protocol; allows customizes authentication security solutions	

*Email Security Solutions using S/MIME, PGP, DKIM, SPF, DMARC, STARTTLS				Common Authorization Mechanisms Authorization ensures the requested activity or object is possible; common methods include implicit deny, access control lists, access control matrixes, capability tables, constrained interface, content & context dependent controls ; these controls help enforce need to know and principle of least privilege & separation of duties Single Sign On (SSO) mechanisms that allow subjects to authenticate once & access multiple objects w/o authenticating again Security Assertion MarkUP Language (SAML) is an open XML based standard to exchange authentication & authorization information OAUTH (OAUTH2.0) is authorization framework described in RFC6149supported by many online sites OpenID Connect (OIDC) OpenID (OI) maintained by OASIS provides authentication & authorization by using OAUTH frameworks building on Open ID standards Kerberos most common SSO method used w/ organizations; primary purpose is to authentication; One server synchronizes with NTP Network time Protocol server, all clients w/ network synchronize to same time			
Virtual Private Network (VPN) based on encrypted tunneling; offers authentication and data protection as a point-to-point solution common protocols are PPTP, L2TP, SSH, TLS, IPSec				Code Review Fagan Inspection: Planning, Overview, Preparation, Inspection, Rework, Follow Up			
Context Aware Authentication used in MDM Mobile Device Management to identify a mobile device							
2 Factor Authentication w/ authenticator app Hash Message Authentication Code One Time Password (HOTP) similar asyn Time Based OTP(TOTP) expires if not used within time limit Just-In-Time (JIT) provisioning solutions automatically create the relationship between two entities so that new users can access resources; JIT systems commonly use SAML to exchange required data				Incident any event that has negative effect on the CIA of an organization’s asset Incident Management Steps Detection -> Response -> Mitigation -> Reporting -> Recovery -> Remediation (root cause analysis performed -> Lesson Learned *After detecting or verifying incident, first step is to limit or contain the scope of the incident while protecting evidence* *SOAR automates response to incidents*			
Security Testing ensures controls are functioning properly							
Service Organizational Controls (SOC 1) audit assess the organization controls impact the accuracy of financial reporting Service Organizational Controls (SOC 2) audit assesses organization controls that affect CIA & privacy of info stored in a system w/in organization under NDA Service Organizational Controls (SOC 3) audit same as SOC2 but for public disclosure				Denial of Service (DoS) attacks prevent a system from responding to legitimate request for service SYN Flood disrupts 3way TCP handshake Smurf employs amplification network to send numerous response ICMP packets to victim; sends spoofed broadcast ping request w/ victim as source address Ping-of-Death sends oversized ping packets to victim causing victim to freeze, crash, or reboot Distributed Denial of Service (DDos) multiple systems attack a single system Distributed – Reflective DoS manipulation traffic or a network service so that the attacks are reflected back to victim from other sources Fraggle uses UDP packets spoofing the IP address of victim Land send spoofed SYN packets to victim using victim address as both source & destination Teardrop attacks fragments of data packets making difficult or impossible to reassemble			
Controls Objectives for Information & Related Technology (COBIT) common framework for auditing; crafted by ISACA; security concept allows managers to bridge the gap between control requirements, technical issues & business risk							
Security Content Automation Protocol (SCAP) automates the interaction between different security systems				System Resilience Single Point of Failure (SPoF) any component that can cause an entire system to fail System Resilience ability of system to maintain a acceptable level of service during a diverse event Fault tolerance ability of a system to suffer a fault but continue to operate High availability use of redundant technologies to allow system to recover quickly from a failure; achieved thru load balancers & failover clusters			
Cloud Shared Responsibility Model							
	SaaS	PaaS	IaaS	Database Recovery Electronic Vaulting database backups are moved to remote site using bulk transfer Remote Journaling Remote bulk transfer more frequently 1hour or less Remote Mirroring most advanced solution live database server maintain at backup site			
Application	x	Customer Manages	Customer Manages				
Data	x	Customer Manages	Customer Manages	Key Terminology			
Runtime	x	x	Customer Manages				
OS	x	x	Customer Manages	DevOp Development & Operations DevSecOps Development Security & Operations			
Virtualization	x	x	x				
Servers	x	x	x				
Storage	x	x	x				
Networking	x	x	x				
SaaS Software as a Service fully functional application typically accessible via web PaaS Platform as a Service must provide customers w/ computing platform, including hardware, operating system & runtime environment IaaS Infrastructure as a Service basic computing resources includes servers, storage & networking resources							
Intrusion Detection System (IDS) responds passively by logging & sending notifications or actively by changing the environment; An active IDS is only IPS is placed inline w/ traffic & includes ability to block malicious traffic before it reaches target							
Intrusion Prevention System (IPS) active IDS attempts to detect & bock attacks before it reaches target							
Redundant Array of Available Disk (RAID) software & hardware solutions							
RAID 0 Striping uses two or more disk improves performance don’t provide fault tolerance RAID 1 Mirroring use two disk which hold same data if one fails other has data to continue system RAID 5 Striping w/ Parity uses three or more disk equivalent of 1 holding the parity bit, parity bit allows for reconstruction of data RAID 6 minimum of 4 disk operates as RAID 5 store parity info on 2 disks protecting against failure of 2 separate disk RAID 10 (RAID 1+0) stripe of mirrors configured as two or more mirrors each configured in a stripe uses at least 4 disk can support more as long as even number of disk							
Deploying multiple servers behind a load balancer protects against only type of risk that would cause a server failover							

Backups Full Backups store complete copy of data set bits to 0 Incremental Backup stores only files modified since most recent full or incremental backup sets bit to 0 Differential Backup store all files that have been modified since time of most recent full backup; longer create time shorter restore time	Disaster Recovery Plan Test Read thru Test simplest; Structured Walk thru tabletop exercise role play scenarios; Simulation test response is tested & measured; Parallel Test simultaneous operations backup & operations; Full Interruption Test stop business at production site test at backup site
Investigations EDiscovery (EDRM) Electronic Discovery Reference model 9 aspects: Information governance ensures info is well organized for future eDiscovery efforts Identification locates info that may need to be responsive to request Preservation ensures the potential discoverable info is protected from alteration or deletion Collection centrally gathered info for use in eDiscovery process Processing Screens for irrelevant info Review examines info to determine what is relevant remove info protected by client /attorney privilege Analysis perform deeper inspection of the content & context of info Production places info into format that can be shared Presentation display the info to witness, court, other parties	Expert systems consists of two or main components : knowledge base a series of if/then statements; inference engine that uses this info to draw conclusions about other data Machine Language Techniques attempt to algorithmically discover knowledge from datasets; Neural Network simulate functions of the human mind by arranging a series of layered calculations to solve problems
Lifecycle Model Waterfall Model iterative model w/ feedback loop : System Requirements, Software Requirements, Preliminary Design, Detailed Design, Code & Debug, Testing, Operations, Maintenance Spiral Model model of models Determine Objectives/ Alternative solutions, Evaluate alternatives, Develop & Verify Procedure, Plan next phase Agile is a philosophy emphasis on need of customer & new quickly developing functional product iterative fashion; Scrum is most popular uses sprints Capability Maturity Model (CMM) intended to help software organizations improve the maturity & quality of their software processes Stages of SW-CMM: Level 1: Initial little or no defined process Level 2: Repeatable reuse of code; basic lifecycle management processes Level 3: Defined operate under set of formal documented software processes; all developed projects constrained to a standard Level 4: Managed quantitative process management & software quality management Level 5: Optimizing process of continuous improvement CI/CD Software Assurance Maturity Model (SAMM) open source program developed by OWASP framework integrating security activity ,information software development includes: Governance practices for metrics, policy, compliance Design threat modeling, security requirements, security architecture Implementation secure build, secure deployment, defect management Verification security testing, requirements driven testing Operations incident response management, env mgmt, operational mgmt. IDEAL Model Initiating Diagnosing Establishing Acting Learning	ISC2 Code Professional Ethics Preamble: The safety & welfare of society & the common good duty to out principles, & to each other, requires that we adhere , & be seen to adhere to the highest ethical standards of behavior; Canons: 1. Protect society & common good, necessary public trust, confidence & the infrastructure; 2. Act honorably, justly, responsibly & legally; 3. Provide diligent & competent service to principles; 4. Advance & protect the profession Least Privilege an aspect of AAA & IAM subject has jus the proper level or amount of frights & privileges to perform hob role NIST 800-53 Least Privilege authorize access to all security functions, use non privileged accounts or roles when accessing non security functions; prevents non privileged users from executing privileged account;audit the execution of secure functions; good for large business; ISO/IEC 27001 access to networks & network services, management of privileged rights, use of privileged utility programs, access control to program source NIST Privacy Framework tool for improving privacy through Enterprise Risk Management goal to protect individual privacy General Data Protection Regulations (GDPR) privacy issues can be different for different countries or jurisdictions *Federal Supply Chain must comply w/ NIST SP800-53 & SP800-17;*Supply chain critical in engaging w/ import/export Data Lifecycle Collection, Location, Maintenance, Remanence , Retention, Destruction; data maintenance is initiated once data created OSINT (Open source Intelligence) any data collected legally from free Automated indicator Sharing (AIS) enables real-time exchange of machine-reachable cyber threat indicators; Structured Threat Information Exchange (STIX) standardized language developed by MITRE to represent structed info about cyber threats; Trusted Automated Exchange of Indicator Information (TAXII) transport vehicle for service & message exchanges to allow the sharing of inf about cyber threats Common Vulnerabilities & Exposures (CVE) MITRE.org used by National vulnerability database consist of Id num, description & public reference Common Vulnerability Scoring system (CVSS) open standard weighting the severity of complex system vulnerabilities; uses uniform & consistent scoring method ranging 0-10; 10 highest severity
Security Models used to decide which subject can access a object Bell-LaPadula Model uses MAC multilevel security used w/government Simple Security Rule no read up Star Property * no write down Strong Star Property Rule subject w/ RW permission can only perform functions at same security level Tranquility Principle subjects & objects cannot change their security level once created Biba integrity model Simple Integrity rule no read down star integrity rule no write up Invocation property subject cannot invoke subject at higher level Clark Wilson (IVP) Integrity Verification Procedures introduced separation of duties; ensure well formed transactions	NIST Cyber Security Framework: Identify, Protect, Detect, Respond, Recover Security Models Key stretching lengths symmetric keys to at least 128 bits common key stretching algorithm Bcrypt & PBKDF2